

SQL Injection

05 July 2026 11:43

SQL injection is a code injection technique used to executed malicious SQL statements.

How SQL injection works?

username abc@xyz.in password 123456

Select * from users where username = "abc@xyz.in" and password = '123456'

OR gate logic

A	B	Out
0	0	0
0	1	1
1	0	1
1	1	1

user input

We use this logic

'OR 1=1 --' → always returns true

to comment the sql

How to use sql injection?

GET :- Data is sent in the url of the request.
localhost/index.php? username=admin & password=admin

POST :- Data is sent in the request body of request method.

SQL Injection :- SQL injection is a code injection technique where SQL is injected by user (as the part of user input) into the backend query. Inject SQL data alters the purpose of original query and upon execution can gives harmful result.

A SQL injection attack is very dangerous and attacker can,

1. Read sensitive data from the database.
2. Update database data (Insert / update / Delete)
3. Slowdown the complete database system. etc.

username: 'saten'. delete from user where id=1 user table

"select * from user where username=''+
username + '";

id	username	password
1	Satyen	mishra
2	Subha	sarkar
3	Baishaki	mishra
4	Nitin	poddar

select * from user where username='satyen';

delete from user where id='1';

At server side, generally, a query is not complete without user data.

Let's understand by taking one example, say you want to get user details for that query will be:

"select * from user where username=''+username+'";

after compilation

select * from user where username='satyen';

↑ attribute in table user.

Is the above query complete and ready to execute?

No, there is dependency on user data.

'username' is the place holder, which is going to be replaced by actual user name of the person stored in our database.

We ask user to enter his/her username, which is going to fill our placeholder username.

Enter your username: |

Do we have control on what the user is going to fill in username?

No, say user has entered.

user can fill anything, like name of animal, hospital etc. or can fill some junk data say 'aahh' and press enter or submit button. (username = \$\$\$\$^aahh*) or user can fill query like say 'username='satyen'; delete from user where id=1';

Server:-

1. { username = dog. Query will turn into

select * from user where username='dog';

2. { username = apollo. Query will turn into

select * from user where username='apollo';

3. { username = \$\$\$\$^aahh* Query will turn into

- 3 { username = '\$\$##^aahh*' Query will turn into
 select * from user where username = '\$\$##^aahh*';
- 4 { username = satyen; Delete from user where id = 1
 Query will turn into
 select * from user where username = 'satyen';
 delete from user where id = '1';

How our application will behave in above cases?

- For case 1, 2, 3 it may or may not harmful behavior but for case 4, it is sure that we are in trouble. Appending user data to our query template, turned query template into two queries and our SQL server engine will execute 2 queries separately.

1. Select Query: select * from user where username = 'satyen';

2. Delete Query: delete from user where id = '1';

This indirect way of injecting SQL code inside the query is called SQL injection.

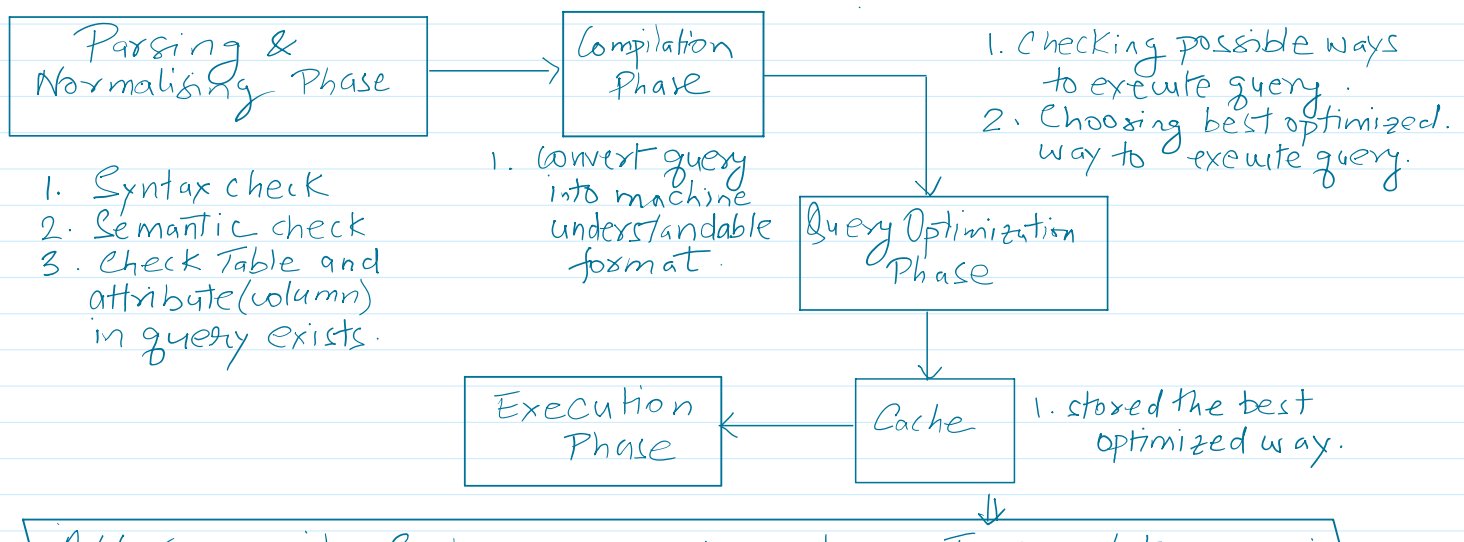
How Prepared Statement in Java Prevents SQL injection?

To understand this, Let's see steps involved in query execution.

1. Compilation Phase

2. Execution Phase

Whenever SQL server engine receives a query it has to pass through below phases.



↓
After compile & before execution phase. In this state query is called Pre-compiled query or already compiled query.

```
package MyJDBCOne;
import java.sql.Connection;
import java.sql.DriverManager;
import java.sql.ResultSet;
import java.sql.SQLException;
import java.sql.Statement;
import java.util.Scanner;
public class SQLInjection {
    public static void main(String[] args) {
        String dbUrl = "jdbc:oracle:thin:@//localhost:1521/FREE";
        String username = "sys as sysdba";
        String password = "Calcutta1983";
        Scanner sc = new Scanner(System.in);
        System.out.println("Enter username : ");
        String user = sc.nextLine();
        System.out.println("Enter password: ");
        String pass = sc.nextLine();
        try {
            Connection con = DriverManager.getConnection(dbUrl, username, password);
            Statement st = con.createStatement();
            // String sql = "SELECT * FROM USERS WHERE username='"+user+
            // "'" And password = '"+pass+"'";
            String sql = "SELECT * FROM USERS WHERE username='"+user+
            "'" OR '1' = '1'";
            System.out.println(sql);
            System.out.println(sql);
            ResultSet rs = st.executeQuery(sql);
            if(rs.next()){
                System.out.println("Login Successful");
            }
            else{
                System.out.println("Invalid user name or");
            }
        } catch (SQLException e) {
            e.printStackTrace();
        }
    }
}
```

Output:

```
Enter username :  
admin  
Enter password:  
782  
SELECT * FROM USERS WHERE username='admin' O  
R '1' = '1'  
SELECT * FROM USERS WHERE username='admin' O  
R '1' = '1'  
Login Successful
```